ATT&CK Threat Model – Home Assistant with Zigbee ZHA (R

Findings ranked highest to lowest priority; tied findings share a rank.

Rank	Finding ID	Affected component / data flow	ATT&CK category
1	**T-01**	P6 Custom integration; DF17	Execution
2	**T-02**	DF2 P1→P2 (HTTP/WS, TB1/TB4)	Credential Access (Network Sniffing, Adversary-in-the-Middle)
2	**T-03**	DF3 EE6→P2 (long-lived token over HTTP)	Credential Access (Adversary-in-the-Middle)
4	**T-04**	P2 Core APIs; DS2; DF12	Persistence (Valid Accounts)
4	**T-05**	EE6 Local script holding long-lived token	Credential Access (Unsecured Credentials)
6	**T-06**	DS7 Local logs; DF18, DF17	Defense Evasion (Indicator Removal)
6	**T-07**	DS5, DS6; P7; DF16, DF17	Impact (Data Destruction, Inhibit System Recovery)
8	**T-08**	P2 login; DF2; DS2	Credential Access (Brute Force)
8	**T-09**	DF10 pairing; DF8; P5; P4	Initial Access
10	**T-10**	EE4 Door and motion sensors (also EE3)	Credential Access
10	**T-11**	DF8, DF9; EE3, EE4; DF4; P3	Impact (data manipulation)
12	**T-12**	DF11 EE5→P4; EE3	Initial Access (Supply Chain Compromise)
12	**T-13**	P3 Automation engine; DS1; DF4, DF5	Impact / Defense Evasion
14	**T-14**	DF8, DF9; P5; EE3, EE4	Impact (Network Denial of Service)
14	**T-15**	EE2 Ordinary member; DF1; DF6	Impact (abuse of legitimate access)

Revision 1.0 package)

Threat mechanism and consequence
The malicious community integration runs in Core with no sandbox. It reads DS1–DS7, including DS3 Zigbee keys and DS5 backups with the local DS6 key, plus process memory. It can also issue commands through P2/P4. One component compromises all stores and the plug and bulb control.
Cleartext passwords, refresh/access tokens and the event stream cross the flat LAN. A listener can replay a session, impersonate the administrator, or learn occupancy and door events.
The administrator-owned script sends its non-expiring token in cleartext on each call. A captured token gives durable admin API access that survives password changes until the token is revoked.
An attacker using a stolen admin credential or token creates an extra long-lived token or account. Access then outlasts the original theft, a password reset and token expiry.
The literal token lives in the script's environment, not in Home Assistant. Compromising that host or reading the script's storage yields persistent admin access with no network sniffing.
Logs sit only on the same host, with no central archive. Core-privileged code can delete or alter authentication, integration and backup events, hiding T-01 or T-04 activity.
The archive, its key and live data share one failure domain with no off-host copy. Malicious code can delete or corrupt DS5/DS6 along with live stores, leaving no restorable backup even with the offline key.
Unauthenticated password guessing against login, with no MFA and no automatic IP ban, can compromise an account. Admin success gives full control.
During the 60-second pairing window, a nearby rogue device joins or captures the network key under conventional (non-install-code) joining. It becomes a trusted mesh member with the shared key.
Brief outside access to an end device could expose the shared network key. One extraction compromises the whole mesh, since encryption gives no per-device authorization.
An attacker holding the network key forges door or motion reports, or commands the plug and bulb. This can suppress alerts, trigger automations falsely or toggle devices. Frame counters stop replay, not forgery by a key holder.
If an unsigned or substituted firmware image or metadata reached ZHA from the provider path, a router could run attacker code and hold the network key.
An administrator-level actor edits automations to disable door/motion-driven rules or force unwanted plug and bulb actions.
Radio jamming or flooding interrupts coordinator-to-device traffic, so sensor reports and plug/bulb control are lost for the duration.
An ordinary user, with no per-device allowlist, operates any configured device and could switch off the plug or bulb against household intent.

Required initial attacker access	Additional assumption	Priority
Malicious integration installed in Core (in-scope attacker)	None	High
LAN guest or compromised LAN device	Attacker can observe or redirect traffic (e.g., ARP spoofing or shared medium)	High
LAN guest or compromised LAN device	Attacker can observe or redirect traffic	High
Stolen administrator credentials or token	Administrator role can create additional tokens or accounts (package says admin-only actions exist but not which)	Medium
Compromised LAN device	Attacker can read the script's token storage (the script's host is the compromised device or is reachable)	Medium
Malicious integration (P6)	P6 has write or delete rights on DS7 (package states access, not write)	Medium
Malicious integration (P6)	P6 can write or delete DS5/DS6	Medium
LAN guest (unauthenticated)	A weak or reused password exists, and throttling tolerates slow or distributed guessing (attempt count not stated)	Medium
Nearby radio attacker (receive and transmit)	Attacker can time or detect the window, and conventional joining exposes the join or key to nearby active attackers	Medium
Brief physical access to an end device	Key extraction is feasible in that time (package says this is not implied)	Medium
Nearby radio attacker holding the network key	Key obtained via T-09, T-10 or T-01; counters tracked successfully	Medium
None of the listed attackers directly; closest is stolen admin credentials initiating install	Provider content is tampered with by an external party (not an insider) or admin settings are changed, and the device accepts an unsigned image	Low
Stolen administrator credentials or token	None	Low
Nearby radio attacker (transmit)	None	Low
Ordinary household member account	None	Low

Priority justification
Total confidentiality and integrity loss. No isolation, and the offline recovery key is the only item it cannot reach.
Cleartext is an explicit deployment choice. One captured admin session yields full control.
Frequent use makes capture likely. No expiry or MFA limits the damage.
Severe, but it depends on a prior credential theft (T-02, T-03, T-05, T-08).
Single point of token exposure. It needs a second foothold in the household.
Removes the only local evidence. It is an enabler rather than an initial compromise.
Large availability impact, but it requires an attacker already inside Core.
Throttling is a real control, but MFA is absent and admin impact is high.
Severe if it succeeds, but the short window and admin-only trigger limit likelihood.
High consequence, but the extraction path is unestablished and needs skill.
Directly affects occupancy and door-event integrity, but it chains off other findings.
HTTPS and the admin-initiated install limit this. It rests on several unestablished premises.
Real but narrow. Controlled devices are limited to one plug and one bulb.
Transient and loses no data. Detection impact is limited to the outage.
Uses permitted functions, and the household is a small trust group.

Summary (formulas reference the Findings and Coverage sheets)

Priority	Count
High	3
Medium	8
Low	4
Total findings	**15**

Coverage

Elements considered	42
Elements with no distinct threat	6
Elements with at least one finding	36

Note: the coverage checklist is not part of the finding count.

Coverage checklist – every element ID considere

Not part of the finding count.

Element ID	Name
EE1	Household administrator
EE2	Ordinary household member
EE3	Zigbee routers (plug, bulb)
EE4	Zigbee end devices (door, motion)
EE5	Manufacturer OTA provider
EE6	Local script with long-lived token
P1	Frontend on browser or phone
P2	Core APIs, auth state machine, event bus
P3	Automation engine
P4	ZHA inside Core
P5	USB coordinator firmware
P6	Custom integration
P7	Backup manager
DS1	Configuration and integration secrets
DS2	Accounts, hashes, token records
DS3	Zigbee keys, device list, network state
DS4	Recorder state and event database
DS5	Encrypted local backup archive
DS6	Backup encryption key material
DS7	Local application logs
DF1	User input to P1
DF2	P1→P2
DF3	EE6→P2
DF4	P2→P3
DF5	P3→P2
DF6	P2→P4
DF7	P4→P5 (USB serial)
DF8	P5→EE3/EE4 (radio)
DF9	Mesh relay traffic
DF10	Pairing request
DF11	OTA fetch (EE5→P4)
DF12	P2→DS1/DS2
DF13	P4→DS3
DF14	P2→DS4
DF15	P7 reads DS1–DS4
DF16	P7→DS5/DS6
DF17	P6 access with Core privileges
DF18	P2/P4/P7→DS7
TB1	LAN to Core
TB2	Core to coordinator and radio
TB3	Core to manufacturer service
TB4	Unauthenticated, ordinary and admin privileges

d

Associated finding IDs
T-02, T-04
T-15
T-10, T-11, T-12, T-14
T-10, T-11, T-14
T-12
T-03, T-05
No distinct threat identified
T-01, T-02, T-03, T-04, T-08
T-11, T-13
T-01, T-09, T-12
T-09, T-14
T-01, T-06, T-07
T-01, T-07
T-01, T-13
T-01, T-04, T-08
T-01
T-01
T-01, T-07
T-01, T-07
T-06
No distinct threat identified
T-02, T-08
T-03
T-11, T-13
T-13
T-01, T-15
No distinct threat identified
T-09, T-11, T-14
T-11, T-14
T-09
T-12
T-01, T-04
No distinct threat identified
No distinct threat identified
No distinct threat identified
T-07
T-01, T-06, T-07
T-06
T-02, T-03, T-08
T-09, T-10, T-14
T-12
T-01, T-15